

Enterprise Risk & Control Summary

Integrated risk register, control ownership, treatment actions, and validation criteria

Risk ID	Scenario	Inherent	Control owner	Key control(s)	Treatment action	Target	Residual	Val
CR-01	Privileged account compromise	Critical	IAM Lead	MFA, PAM, access review, admin logging	Remove standing excess privilege; enforce phishing-resistant MFA	Day 30	Medium	Acc cov test
CR-02	Internet-facing critical vulnerability exploited	Critical	Infrastructure Lead	Scanning, patching, WAF, asset inventory	7-day SLA, owner escalation, emergency change process	Day 30	Medium	Aut con
CR-03	Security blind spot from missing logs	High	SOC Lead	SIEM, retention, source standard	Onboard identity, endpoint, WAF, firewall, cloud admin logs	Day 60	Medium	Test and
CR-04	Ransomware impacts systems and backups	High	IT Operations	EDR, segmentation, backups, IR	Immutable copy, quarterly restore tests, isolation playbook	Day 60	Medium	Res doc
CR-05	Unauthorized SaaS / vendor access	High	GRC / Procurement	Vendor review, SSO/MFA, access expiry	Tier vendors; annual reassessment; sponsor review	Day 90	Medium	High con
CR-06	Sensitive data shared externally	High	Data Owner	Classification, DLP, encryption, RBAC	Define restricted-data controls and DLP alert workflow	Day 90	Medium	DLP rev
CR-07	Delayed incident escalation	High	IR Lead	Severity matrix, contact tree, playbooks	Tabletop exercise and contact validation	Day 60	Medium	Exe trac
CR-08	Excess service-account privileges	High	Application Owner	Named owner, rotation, least privilege	Inventory, owner assignment, rights reduction, secret rotation	Day 60	Medium	Per evi

Risk Governance Rules

- Critical risks receive immediate visibility and active treatment plans.
- High risks require named owners, target dates, and monthly status review until reduced.
- Risk acceptance is time-bound and documents business rationale, compensating controls, approval, and review date.
- Risk closure requires operating evidence, not only a completed ticket.